Security Audit Report

Active Directory | Microsoft Entra ID | Auth0 | Hybrid Identity

Self-directed portfolio project | October 2026

This report documents a security configuration and evidence review within an isolated IAM lab. It is not an independent production security audit. Observations are based on the configurations, screenshots and test results recorded during the project.

1. Executive overview

The assessment covers identity administration, authentication controls, least-privilege access, application ownership, federated sign-in and hybrid directory synchronisation. The lab demonstrated remediation of weak Active Directory password settings, unnecessary departmental access and missing application ownership. Selected MFA and federated authentication scenarios were validated, alongside successful synchronisation of an on-premises test identity to Microsoft Entra ID.

The report distinguishes configured controls from verified outcomes. Privileged access, service-account ownership, tenant-wide MFA coverage and some Conditional Access scenarios require further assessment.

2. Assessment scope

The review included the **iamlab.local** Active Directory domain, departmental organisational units, groups, password policy and service accounts; Microsoft Entra ID users, Conditional Access and application registrations; PowerShell-based identity operations; Entra ID–Auth0 federation; and Microsoft Entra Connect Sync running on **EntraConnect01**.

3. Summary of findings

Area	Assessment	Status
AD password policy	Minimum length and lockout configuration strengthened	Remediated
Departmental access	Unnecessary IT and HR memberships removed	Remediated
Application ownership	Owner assigned to Auth0 registration	Remediated
Conditional Access	Two custom policies On; two Report-only	Partial enforcement
Hybrid identity	Test account synchronised to Entra ID	Verified test
Privileged access	Effective Admin-Access permissions unconfirmed	Open
Service accounts	Ownership and dependencies not documented	Open
MFA coverage	Selected sign-in validated; tenant-wide review absent	Open

4. Active Directory password security

The default domain policy was assessed and remediated using PowerShell. Configuration checks confirmed the following settings:

Setting	Before	After
Minimum password length	7	14
Password complexity	Enabled	Enabled
Password history	24	24
Maximum password age	42 days	No routine expiry
Lockout threshold	Disabled	10 failed attempts
Lockout duration	30 minutes	30 minutes

The revised configuration was verified. Existing user passwords were not individually reset or checked for compromise. In production, a no-routine-expiry approach would require complementary controls such as MFA, compromised-password detection and a defined reset process.

5. Conditional Access and MFA

The Microsoft Entra ID policy inventory shows four Microsoft-managed policies in the On state: Block legacy authentication; Multifactor authentication for Azure Management; Multifactor authentication for admins; and Multifactor authentication for all users. Four user-created policies were configured as follows:

Custom policy	State	Assessment
CA001 - Block Non-Compliant Devices	Report-only	Evaluates impact; does not block access
CA002 - Require MFA - All Users	On	Enabled; coverage not comprehensively tested
CA003 - Restrict Admin Portal - Locations	Report-only	Location restriction not enforced by this policy
CA004 - Require MFA - Risky Sign-ins	On	Enabled; risk scenarios not fully tested

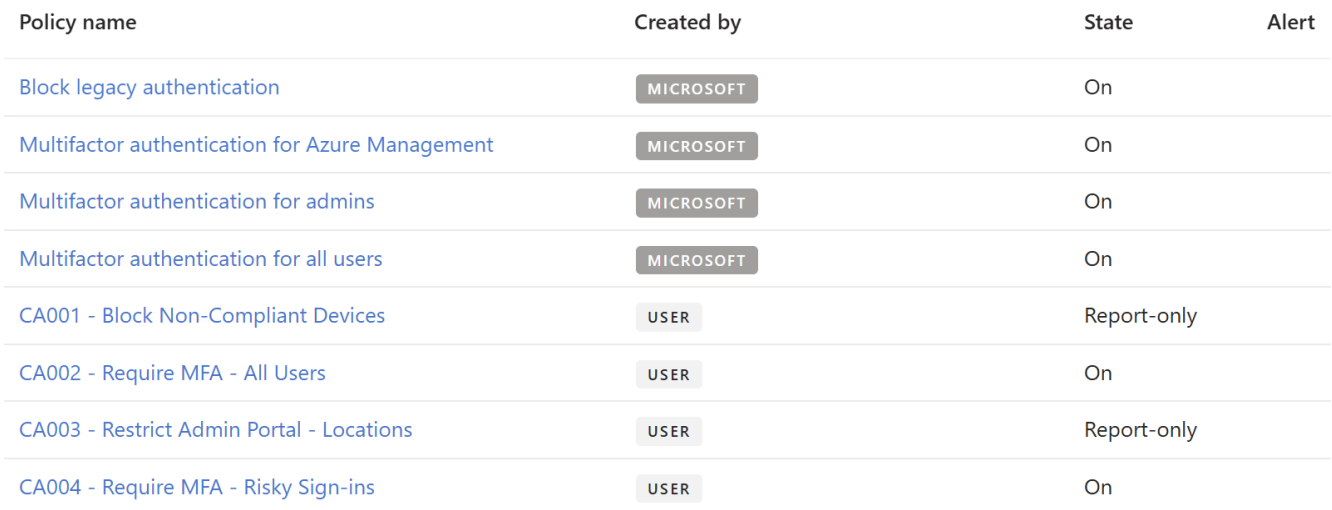


Figure 1. Microsoft Entra ID Conditional Access policy inventory.

A selected test account completed MFA registration and a successful Entra ID–Auth0 federated sign-in. This confirms the tested authentication path, not comprehensive MFA enforcement across every lab account. Policy assignments, exclusions and sign-in results require further review.

6. Access review and privileged identities

The access review identified unnecessary IT-Staff and HR-Staff memberships for **sdunce** (Sarah Dunce). Both memberships were removed. Verification showed the account retained Sales-Staff and Domain Users, consistent with the lab access requirement.

PowerShell scripts supported onboarding, offboarding and access-review exercises. A scenario involving an unauthorised Admin-Access group membership change was investigated using security event evidence and remediation steps. The **jboom** Admin-Access membership remains an open finding because effective group permissions and access justification were not established. A full inventory of privileged AD and Entra identities and a comprehensive 90-day stale-account assessment were not confirmed.

7. Service accounts and application identities

Two AD service accounts, **svc_backup** and **svc_monitoring**, were reviewed. Both were disabled, neither had an owner recorded in ManagedBy, and no PasswordLastSet value appeared in the collected results. They were retained pending dependency checks.

The Auth0 IAM Federation application registration was reviewed and an owner assigned. Its recorded delegated Microsoft Graph permission was User.Read. A client secret labelled Auth0-Federation-Lab had an expiry date of 4 September 2027. Application permissions and credential expiry remain periodic review considerations.

8. Federation and application access

Microsoft Entra ID was integrated with Auth0 using OpenID Connect. A test account completed MFA registration and successfully authenticated through the federated sign-in flow. Group-based application assignments were also explored. Negative testing, revocation behaviour and comprehensive access validation were outside the confirmed test evidence. Okta integration was not completed due to account registration requirements.

9. Hybrid identity synchronisation

A dedicated Windows Server 2022 instance, **EntraConnect01**, was joined to **iamlab.local** and configured with Microsoft Entra Connect Sync to integrate with the **iamlab133.onmicrosoft.com** tenant. Custom configuration included OU filtering for Finance, HR, IT and Sales and Password Hash Synchronisation.

Synchronisation Service Manager recorded successful Full Import and Full Synchronisation operations for the on-premises AD connector. A metaverse search returned 11 person objects, including the Hybrid Test identity. These results confirm local directory import and processing, rather than cloud provisioning on their own.

Staging mode was identified as the reason synchronisation exports were not occurring and was disabled. The **hybridtest** account was then verified in Microsoft Entra ID with on-premises synchronisation enabled, a recorded last-sync timestamp, distinguished name, immutable ID, SAM account name and source domain. This provides evidence of cloud provisioning for the tested identity.

Full lifecycle propagation, password-based cloud authentication, all-user synchronisation coverage, error monitoring and recovery scenarios were not comprehensively validated. AD Recycle Bin and TPM recommendations are retained as infrastructure hardening considerations.

10. Prioritised recommendations

Priority	Recommended action
High	Inventory privileged identities and validate Admin-Access permissions and membership justification.
High	Review MFA registration, exclusions and sign-in outcomes for relevant Entra users.
Medium	Evaluate report-only CA001 and CA003 through controlled sign-in tests before enforcement.
Medium	Document service account owners, dependencies and retention decisions.
Medium	Complete 90-day inactivity review and confirm account lifecycle decisions.
Medium	Extend hybrid tests to account changes, disablement, authentication and sync failures.
Low	Review AD Recycle Bin and TPM recommendations for the lab infrastructure.

11. Conclusion

This security audit provided an opportunity to assess the identity and access management controls implemented across my lab environment, identify potential security weaknesses and address areas requiring improvement.

Throughout the project, I strengthened Active Directory password policies, reviewed and corrected unnecessary group memberships, configured Conditional Access policies and validated authentication through Microsoft Entra ID and Auth0. I also implemented hybrid identity synchronisation, gaining further practical experience with how identities are managed across on-premises and cloud environments.

Although several security improvements were successfully implemented and verified, some areas still require further assessment, particularly privileged access, MFA coverage and service account management.

Overall, this project has helped me develop a better understanding of IAM security, particularly the importance of regularly reviewing access, applying appropriate security controls and verifying that configurations work as intended.